

# Incident Report Analysis

ICMP Flood DoS Attack (NIST CSF)

Analyst: Mohammad

Framework applied: NIST Cybersecurity Framework (CSF)

Organization: Multimedia company (web design, graphic design, social media marketing)

## Summary

The organization experienced a Denial of Service (DoS) attack that disrupted its internal network for two hours. Network services suddenly stopped responding due to an incoming flood of ICMP packets, which prevented normal internal traffic from accessing network resources. Investigation determined that a malicious actor sent the flood of ICMP pings through an unconfigured firewall, exploiting the lack of any traffic-filtering rules. The incident management team responded by blocking incoming ICMP packets, taking non-critical services offline, and restoring critical services, resolving the immediate disruption within two hours.

**Note on classification:** the scenario refers to this incident as both a “DoS attack” and a “distributed denial of service (DoS) attack.” Based on the details provided — a single malicious actor, with no indication of multiple distributed source IPs — this incident is classified here as a DoS attack, not a DDoS attack.

## Identify

**Technology/Assets affected:** The organization's firewall (which had no configured filtering rules) and the broader internal network and connected services. The flood of ICMP traffic passed unfiltered through the firewall, consuming network resources and rendering internal services unreachable.

**Attack path:** A malicious actor sent a high volume of ICMP echo request packets into the network. Because the firewall had no rules in place to filter or rate-limit this traffic, the flood reached the internal network directly and overwhelmed it, consistent with an ICMP flood-based DoS attack.

**Business processes affected:** All internal network-dependent operations were disrupted for the duration of the incident. Non-critical services were deliberately taken offline as part of the response, further limiting operations until resolution.

**People needing access:** IT/network security staff and the incident management team required access to the firewall and network infrastructure to diagnose and resolve the issue.

## Protect

Three of the four remediation measures implemented after this incident are Protect-category safeguards — controls that actively block or limit malicious traffic before it can cause harm, rather than simply alerting staff to its presence:

- **Firewall rate-limiting rule:** restricts the volume of incoming ICMP packets allowed through, directly preventing a repeat flood of this scale.
- **Source IP address verification:** checks incoming ICMP packets for spoofed source addresses, blocking disguised traffic before it reaches internal systems.
- **IDS/IPS filtering:** actively filters out ICMP traffic with suspicious characteristics — the IPS (prevention) function specifically, since it blocks rather than only alerts.

**Additional recommended safeguard:** the root cause was an unconfigured firewall with no filtering rules at all. The organization should conduct a full firewall configuration review and establish a documented baseline to ensure no other protocols or ports are similarly left unfiltered.

## Detect

Only one of the four implemented measures falls into the Detect category: network monitoring software, which monitors for abnormal traffic patterns and alerts staff rather than blocking traffic directly. This represents a relative gap — three controls actively block future attacks, but only one helps staff notice unusual activity early. Recommended additions:

- A SIEM tool to aggregate logs from the firewall, IDS/IPS, and monitoring software into one dashboard.
- Defined alert thresholds for ICMP traffic volume, triggering immediate notification on unusual spikes.
- Regular audits of firewall logs and configuration to confirm filtering rules remain correctly applied.

## Respond

- **Containment:** Apply/verify rate-limiting and IP-verification rules; take non-critical services offline if needed.
- **Communication:** Notify IT staff and stakeholders promptly; update affected end users until resolution.
- **Analysis:** Use firewall, IDS/IPS, and monitoring data to confirm attack type before finalizing response.
- **Mitigation:** Block/rate-limit the offending traffic type; isolate affected non-critical systems.
- **Improvement:** Review whether existing controls performed as expected; update rules and signatures accordingly.

## Recover

- **Immediate recovery needs:** Verify each non-critical service individually before restoring it.
- **Recovery process:** Restore critical services first, then non-critical services once controls are confirmed effective.
- **Process improvements:** Document the full incident timeline and root cause as a reference baseline.
- **Communication:** Inform affected teams and clients once service is restored, with a brief cause summary.

## Reflections / Notes

This incident highlights how a single missing control — firewall traffic filtering — created an exploitable gap despite the organization otherwise operating normally. Applying the NIST CSF surfaced an important imbalance in the response: three of the four new safeguards strengthen Protect, while only one strengthens Detect. Future security planning should prioritize closing that detection gap, since earlier detection could reduce both the impact and duration of similar incidents going forward.

## Self-Assessment

| # | Criterion | Met? |
|---|-----------|------|
|---|-----------|------|

|   |                                                               |     |
|---|---------------------------------------------------------------|-----|
| 1 | Includes a summary of the incident                            | Yes |
| 2 | Identifies attack type and extent, including affected systems | Yes |
| 3 | Offers a plan to protect the network from future incidents    | Yes |
| 4 | Describes methods for detecting security events in the future | Yes |
| 5 | Outlines a response process for similar future incidents      | Yes |
| 6 | Lists procedures to recover from a similar security event     | Yes |

**Result: 6/6 criteria met.**